

README – Kit de Encuesta GRC de Ciberseguridad en España

1. Contenido del kit

El kit incluye:

- encuesta_grc.md – Modelo de encuesta integral GRC.
- guia_metodologica_grc.md – Guía metodológica para diseño, aplicación y análisis.
- narrativa_grc.md – Narrativa explicativa para contextualizar y comunicar resultados.
- mapeo_normativo_grc.md – Tabla de mapeo de preguntas a marcos normativos.
- plantilla_igm_roi.md – Especificación de plantilla Excel para IGM y ROI.
- plantilla_reporte_ejecutivo.md – Estructura tipo PowerPoint para reporte a dirección.

2. Objetivo del kit

Proporcionar un paquete coherente para:

- Diseñar y desplegar una encuesta GRC de ciberseguridad a organizaciones españolas.
- Recoger datos comparables sobre madurez de gobernanza, riesgo y cumplimiento.
- Facilitar el análisis, cálculo de IGM y aproximaciones de ROI.
- Comunicar los resultados a órganos de gobierno, reguladores y otros grupos de interés.

3. Cómo utilizar cada componente

1. Encuesta: adaptar el modelo a la realidad sectorial, revisar terminología y publicar en la herramienta elegida.
2. Guía metodológica: usar como referencia para definir muestras, ponderaciones y tratamiento estadístico.
3. Narrativa: servir como base para presentaciones, informes y materiales de sensibilización interna.
4. Mapeo normativo: vincular los resultados a programas de cumplimiento y planes de auditoría.
5. Plantilla IGM/ROI: implementar en Excel, ajustando pesos y supuestos según el contexto.
6. Plantilla de reporte ejecutivo: estructurar mensajes para comités de dirección y consejos.

4. Actualización y versiones

Los marcos normativos y las amenazas evolucionan, así que el kit debe revisarse periódicamente:

- Revisión recomendada: anual o tras cambios relevantes en NIS2, DORA, ENS, etc.[web:9][web:12][web:5]
- Control de versiones: mantener un registro de cambios (changelog) con fecha y responsable.

5. Licencia y uso

El kit está pensado para uso libre dentro de organizaciones, consorcios sectoriales y administraciones públicas. Cada usuario es responsable de:

- Ajustar el contenido a sus necesidades específicas.
- Asegurar que el uso de los resultados respeta la confidencialidad y la normativa vigente (incluyendo protección de datos).
- Evitar la tentación de utilizar el IGM como arma arrojadiza entre departamentos.

6. Contacto y contribuciones

Se recomienda establecer un punto de contacto (equipo de GRC o comité de ciberseguridad) para:

- Resolver dudas sobre la aplicación de la encuesta.
- Recoger sugerencias de mejora.
- Coordinar nuevas versiones y ampliaciones.

Si el kit sirve para mejorar la conversación entre negocio, tecnología y reguladores, habrá cumplido con creces su misión. El resto —como casi siempre en ciberseguridad— será cuestión de gobernanza, prioridades y un cierto gusto por medir las cosas aunque los resultados no sean siempre halagadores.